

Multi-Platform GRC Orchestration Project

Phase Focus: Day 3 – Audit Execution, Attestation, and Framework Harmonization (CCF)

Target Frameworks: AICPA SOC 2 (Revised 2022) & ISO/IEC 27001:2022

Target Organization: PayGuard Inc.

Auditor Accountable: Bhushan Kotiyan, GRC Function & Audit Engineering Lead

System Timestamp: June 26, 2026

1. Executive Summary

While Days 1 and 2 focused entirely on static environment initialization, data model plumbing, and scoping infrastructure boundaries within Jira and ServiceNow, Day 3 marks the operational transition into active **Audit Execution and Framework Harmonization**. Legacy compliance models fail because they treat security checks as point-in-time annual exercises managed through fragmented spreadsheets. Modern GRC engineering transforms this paradigm into a continuous compliance telemetry pipeline.

Over the course of this phase, the system lifecycle was advanced from design to validation. A freshly compiled live ServiceNow control instance was moved through its complete lifecycle (Draft to Compliant), backed by fine-grained operational narratives and procedural evidence artifacts. Furthermore, a unified Common Control Framework (CCF) was programmatically constructed by establishing many-to-one cross-mappings between isolated frameworks, effectively eliminating audit fatigue and duplicative review cycles for engineering teams.

2. Control Lifecycle Activation & Workflow Diagnostics

The primary execution lifecycle targeted the live control instance **CTRL0020001** (*Code of Conduct and Ethical Governance Framework*), which was automatically provisioned on Day 2 via the *All Cloud Infrastructure Providers* Entity Type matchmaker to protect the isolated *AWS Production Cloud Environment* asset layer.

System Diagnostic & Resolution: Upon attempting to advance the control from **Draft** into the **Attest** state, the system successfully changed states but failed to generate an active evaluation record, returning a '*No records to display*' message under the Classic Attestations list view. System troubleshooting identified that the Attestation Template field had been left blank upon compilation. This was systematically resolved by returning the control to Draft, assigning the GRC Classic Attestation template standard, and re-triggering the workflow banner. This successfully spun up active Assessment Instance **AINST0010005** assigned directly to the System Administrator.

3. Full-Stack Evidence Ingestion & Narrative Verification

To satisfy rigorous multi-platform third-party audit trail validation requirements, the assessment questionnaire was fulfilled with high-fidelity qualitative affirmations and technical proof attachments:

- **Mandatory Audit Narrative:** Evaluated and entered the following text directly into the system 'Explain' container:
'The Code of Conduct and Ethical Governance Framework is formally implemented, reviewed, and updated annually by executive leadership. Formal policy sign-offs and corporate compliance alignment parameters are centralized within the attached Corporate Policy Handbook Macro-Package, verifying operational effectiveness across all personnel and assets assigned to the AWS Production Cloud Environment.'

- **Technical Evidence Attachment:** Programmatically attached the physical file artifact Corporate Policy Handbook Macro-Package.pdf containing corporate master policy signatures, access control charters, and secure SDLC guidelines.
- **The Score Roll-Up:** Submitting the completed assessment advanced the control's state to **Compliant**. ServiceNow's calculation engine immediately updated the downstream metrics, flipping the Compliance score (%) from an unverified 0% state into a solid **100% Green Compliant Ring** on the central Executive Dashboard.

4. Common Control Framework (CCF) Multi-Framework Harmonization

To achieve true operational scalability, a cross-mapping harmonization strategy was executed to consolidate multiple compliance mandates onto our single framework-neutral control objective.

Database Collection Isolation Bypass: To map the corresponding ISO 27001 constraint, the Citations Slushbucket list was launched via the *Edit...* button. However, the left-hand *Collection* column returned empty (--None--). This was identified as expected database behavior, because the ISO 27001 framework was ingested exclusively within the Jira Action Layer on Day 1, leaving ServiceNow's native governance tables unpopulated. To bypass this roadblock, the **New** button was utilized to generate an inline, framework-neutral citation mapping for **ISO/IEC 27001:2022 A.5.1 (Policies for Information Security)** directly alongside the existing **AICPA SOC 2 Citation CC1.1**.

The Automation Result: Through this many-to-one relationship, the underlying live control inherits both regulatory compliance directives. A single operational evidence upload now simultaneously satisfies two distinct global standards, dramatically reducing organizational audit drag.

5. Cross-Platform Metadata Lineage Tracking

To guarantee comprehensive audit accountability, an explicit cross-system lineage trail was logged directly within the Supplemental guidance data field of the master Control Objective:

[Cross-Platform Lineage] This control objective is operationally driven via the agile execution layer in Jira Software under Internal Audit Tracking Ticket: ISO-A.5.1 (Domain 5).

This configuration ensures that an external registrar or auditor inspecting the centralized ServiceNow governance record can immediately pull up the corresponding ticket in Jira to view historical team commentary, engineering task assignments, and baseline velocity parameters.

6. Jira Database Structure & Quantitative Vulnerability Analysis

A comprehensive quantitative analysis executed on the active Jira audit registry database (Jira.csv) reveals a dual-track strategy applied to the 99 total control tracking items:

Jira Issue Status	Count	Operational Allocation Strategy
Done	91	Macro-Evidence Packages: Bulk-processed administrative, physical, and people controls using centralized policy handbooks to prevent audit fatigue.
In Progress	4	Critical Vulnerability Gaps: Isolated technological cloud infrastructure flaws under active investigation.

Idea (To Do)	4	Remediation Engineering Tasks: Dedicated tickets assigned to technical infrastructure owners with strict SLAs.
--------------	---	---

The 4 active cloud infrastructure vulnerabilities discovered in the Technological domain are formalized into a quantitative corporate Risk Register pursuant to **ISO/IEC 27001 Clause 6.1.2** (*Risk Score = Inherent Likelihood x Inherent Impact*), carrying strict engineering SLAs:

1. **Credential Exposure Risk (Risk Rating: 16 - HIGH):** Secret tokens and API keys committed to internal private repositories due to licensing constraints on GitHub Advanced Security. Tracked under open ticket KAN-169 (Remediation: KAN-15). **SLA: July 7, 2026 (14 Days)**.
2. **Lateral Network Movement (Risk Rating: 15 - HIGH):** A live, bi-directional AWS VPC Peering connection linking the Staging VPC directly to the Production VPC to facilitate rapid developer testing. Tracked under open ticket KAN-170 (Remediation: KAN-23). **SLA: July 7, 2026 (14 Days)**.
3. **Delayed Incident Detection (Risk Rating: 12 - MED):** Absence of automated real-time SIEM/Datadog alerting configurations for critical cloud control plane modifications, relying on manual bi-weekly cycles. Tracked under open ticket KAN-171 (Remediation: KAN-19). **SLA: 30 Days**.
4. **Data Breach via Backup Leak (Risk Rating: 10 - MED):** Production RDS PostgreSQL database instances relying on default AWS-managed KMS keys instead of a Customer Managed Key (CMK), preventing fine-grained access isolation. Tracked under open ticket KAN-168 (Remediation: KAN-27). **SLA: 30 Days**.

7. Programmatic Integration Automation Blueprint (Day 4 Core)

To completely eliminate manual synchronization overhead, the next architectural milestone establishes a native, automated data pipeline between the two core engines via **ServiceNow IntegrationHub** and the pre-configured **Jira Spoke**.

Whenever a security engineering ticket transitions to *Done* within Jira, an outbound HTTPS REST webhook triggers a payload containing base64-encoded evidence attachments. ServiceNow catches this object, streams the artifact directly into the `sys_attachment` table tied to the targeted control record, and executes a programmatic state alteration to **Compliant**. This automates the continuous compliance roll-up telemetry, rendering spreadsheets obsolete.

End of Day 3 Documentation — System Environment Locked & Synchronized